

Durcissement d'un serveur Linux

Authentification SSH par clé, pare-feu UFW et script d'audit — Ubuntu Server / VirtualBox

Objectifs

L'objectif est de sécuriser un serveur Ubuntu (VM VirtualBox) en appliquant les mesures de durcissement fondamentales d'un serveur exposé au réseau : suppression de l'authentification par mot de passe au profit de clés cryptographiques, filtrage réseau par pare-feu selon une politique de refus par défaut, puis vérification automatisée de l'état de sécurité via un script d'audit développé en Bash.

Le projet couvre les compétences suivantes :

- Génération et déploiement de clés SSH ed25519 (poste Windows → serveur Linux)
- Durcissement du service OpenSSH (sshd_config et fichiers d'override sshd_config.d)
- Configuration réseau d'une VM (passage NAT → pont, netplan, DHCP)
- Mise en place d'un pare-feu UFW selon le principe du refus par défaut
- Développement d'un script d'audit Bash avec rapport horodaté
- Tests et validation de chaque mesure de sécurité appliquée

Environnement

Élément	Détail
Hyperviseur	Oracle VirtualBox (hôte Windows 11)
Système invité	Ubuntu Server 26.04 LTS
Réseau	Accès par pont (bridge) — IP DHCP 192.168.1.169/24
Client SSH	OpenSSH sous Windows PowerShell
Services audités	OpenSSH (sshd), UFW, comptes locaux, mises à jour APT

La VM était initialement en mode NAT avec une adresse IP statique (10.0.2.100) définie dans netplan, ce qui empêchait toute connexion SSH depuis l'hôte. La configuration a été corrigée en deux temps : passage de l'adaptateur VirtualBox en mode pont, puis réécriture de la configuration netplan pour repasser en DHCP.

```
# /etc/netplan/00-installer-config.yaml
network:
  version: 2
  ethernets:
    enp0s3:
      dhcp4: true
```

Étape 1 — Authentification SSH par clé

Une paire de clés ed25519 a été générée sur le poste Windows, puis la clé publique a été déployée sur le serveur dans ~/.ssh/authorized_keys. La connexion par clé a été validée avant toute désactivation du mot de passe, afin d'éviter tout verrouillage hors du serveur.

```
# Poste Windows (PowerShell)
ssh-keygen -t ed25519 -C "josias-ubuntu-secu"
type $env:USERPROFILE\.ssh\id_ed25519.pub | ssh josias@192.168.1.169 ^
"mkdir -p ~/.ssh && cat >> ~/.ssh/authorized_keys"
```

```
# Serveur – permissions strictes
chmod 700 ~/.ssh
chmod 600 ~/.ssh/authorized_keys
```

Étape 2 — Durcissement du service OpenSSH

Trois directives ont été appliquées : interdiction de la connexion root, désactivation totale de l'authentification par mot de passe, et authentification par clé publique explicitement activée.

```
# /etc/ssh/sshd_config
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
```

Point technique rencontré : sur Ubuntu récent, les fichiers de `/etc/ssh/sshd_config.d/*.conf` ont priorité sur `sshd_config`. Un fichier d'override y maintenait `PasswordAuthentication yes`, rendant la directive du fichier principal inopérante. Le diagnostic a été réalisé avec `sshd -T` (configuration effective réellement appliquée par le démon), puis l'override a été corrigé directement.

```
# Vérification de la configuration effective
sudo sshd -t                    # validation syntaxique
sudo sshd -T | grep -i passwordauthentication # -> no
sudo sshd -T | grep -i pubkeyauthentication   # -> yes
sudo systemctl restart ssh
```

Étape 3 — Pare-feu UFW

Le pare-feu applique le principe du moindre privilège au niveau réseau : tout le trafic entrant est refusé par défaut, seul le port SSH (22/tcp) est autorisé. La règle SSH a été ajoutée avant l'activation du pare-feu pour ne pas couper la session d'administration en cours.

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp
sudo ufw enable
```

To	Action	From
22/tcp	ALLOW IN	Anywhere
22/tcp (v6)	ALLOW IN	Anywhere (v6)

Étape 4 — Script d'audit (audit.sh)

Un script Bash d'environ 120 lignes vérifie automatiquement l'état de sécurité du serveur et produit un rapport coloré dans le terminal ([OK] en vert, [!!] en rouge), sauvegardé dans un fichier de log horodaté. Contrôles réalisés :

- Comptes utilisateurs : seul root doit posséder l'UID 0 ; aucun compte sans mot de passe
- Configuration SSH effective via `sshd -T` : `PermitRootLogin`, `PasswordAuthentication`, `PubkeyAuthentication`
- Pare-feu : statut UFW et liste des règles actives
- Ports en écoute (`ss -tulnp`) : détection de services exposés non prévus
- Mises à jour de sécurité APT en attente
- Dernières connexions au système

```
# Extrait – vérification de la configuration SSH effective
pass_auth=$(sshd -T | grep -i "^passwordauthentication" | awk '{print $2}')
if [ "$pass_auth" = "no" ]; then
```

```
    ok "PasswordAuthentication désactivé (connexion par clé uniquement)."  
else  
    warn "PasswordAuthentication est activé !"  
fi
```

Tests de validation

Chaque mesure a été testée individuellement depuis le poste Windows, en confirmant à la fois les accès autorisés et les accès bloqués.

Test	Commande / Méthode	Résultat attendu	Résultat obtenu
Connectivité hôte → VM	ping 192.168.1.169	Réponse (0% perte)	Succès
Connexion par clé	ssh josias@192.168.1.169	Passphrase de la clé demandée, session ouverte	Succès
Connexion par mot de passe	ssh -o PubkeyAuthentication=no ...	Permission denied (publickey)	Bloqué
Connexion root	PermitRootLogin no (sshd -T)	Refusée	Bloqué
Pare-feu actif	sudo ufw status verbose	Status: active, deny incoming	Succès
Seul le port 22 ouvert	Règles UFW + ss -tulnp	22/tcp uniquement autorisé en entrée	Succès
Audit automatisé	sudo ./audit.sh	Tous les contrôles [OK], rapport généré	Succès

Limitations connues

- La commande `last` n'est plus fournie par défaut sur Ubuntu 26.04 (remplacée progressivement par `wtmptdb`) : la section « Dernières connexions » du script est donc inopérante sur cette version. Le reste du rapport n'est pas affecté.
- Le port SSH reste sur la valeur par défaut (22) ; un changement de port et l'ajout de `fail2ban` constituent des pistes d'amélioration.

Compétences démontrées

- Administration d'un serveur Linux headless via SSH
- Cryptographie appliquée : génération et déploiement de clés `ed25519`
- Durcissement d'OpenSSH et diagnostic de configuration effective (`sshd -T`, overrides `sshd_config.d`)
- Configuration réseau : modes VirtualBox (NAT / pont), `netplan`, DHCP
- Pare-feu UFW : politique de refus par défaut et moindre privilège réseau
- Scripting Bash : automatisation d'un audit de sécurité avec rapport horodaté
- Méthodologie : validation de chaque mesure avant la suivante, tests positifs et négatifs